

SHRIVARSHAN KASI ARUL

Avadi, Chennai, Tamil Nadu 600055

☎ +91 8637406402 ✉ shrivarshan81@gmail.com 🌐 My Portfolio 🔗 linkedin.com/in/Shri Varshan K 🐙 github.com/theloav

Summary

Security Engineer with hands-on expertise spanning the full security lifecycle - VAPT, red teaming, application security, DevSecOps pipeline engineering, threat intelligence, SIEM detection engineering, incident response, malware reverse engineering, AI/LLM security assessments, and security auditing (ISO 27001). Experienced operating Microsoft Sentinel, Darktrace, and Defender for Cloud across production environments in collaboration with India and UK teams. Certified in eJPT, CPT, and Fortinet Certified Associate. Recognised in public bug bounty programs with a **#1 Hall of Fame** ranking and critical vulnerability disclosures in live AI agent environments.

Experience

InCorp Global

Security Engineer

August 2025 – Present

On-Site / Chennai, Tamil Nadu

VAPT & Application Security

- Conducted end-to-end VAPT across multiple projects in collaboration with India and UK (London) teams — independently discovered and reported SQL Injection, IDOR, Sensitive Data Exposure, RCE, DoS, Race Condition, XSS, and Buffer Overflow; served as final approver before findings are cleared for production.
- Performed web application, API, network, and mobile penetration testing applying OWASP Top 10 methodology; produced detailed findings reports with risk ratings, proof-of-concept evidence, and remediation guidance.
- Performed security architecture reviews and provided secure design guidance for LLM-based applications, business-critical portals, and enterprise projects; conducted AI/LLM security assessments evaluating prompt injection, model manipulation, and data exposure risks.
- Performed security architecture reviews and delivered secure design recommendations for LLM-based applications and business-critical portals applying OWASP Top 10 for LLMs.

DevSecOps & Application Security Engineering

- Designed and implemented production-grade secure CI/CD pipelines in GitHub Actions and Azure DevOps integrating SAST (Semgrep, SonarQube), DAST (Burp Suite, OWASP ZAP, Acunetix), SCA (Snyk), IaC security (Checkov), and container/Kubernetes scanning (Trivy, Kubesec, Dockle) — enforcing automated quality gates and shift-left security across the full SDLC.
- Managed Snyk for open-source dependency and container vulnerability scanning — integrated into CI pipelines to enforce SCA policy gates before production merge; tracked and triaged vulnerability backlogs across multiple projects.
- Enforced secret detection via Gitleaks across all repositories; managed secure variable handling for API keys and credentials in pipeline environments.

Threat Intelligence, SIEM & Cloud Security

- Managed threat intelligence operations and SIEM detection engineering using Microsoft Sentinel — authored and tuned KQL-based detection rules, correlation policies, and alert thresholds; performed ongoing tuning to reduce false-positive volumes.
- Deployed and operated Darktrace across Email, Identity, Endpoint, and Attack Surface Management (ASM) modules — acknowledged, investigated, and triaged AI-surfaced threats and behavioural anomalies across identity and endpoint telemetry.
- Maintained cloud security logging pipelines from AWS (GuardDuty, CloudTrail, VPC Flow Logs) and Azure (Defender for Cloud, Entra ID audit and sign-in logs, Diagnostic Settings) into SIEM; configured M365 Defender connectors including Exchange Online.

Incident Response & Malware Reverse Engineering

- Identified and responded to a P1 live security incident involving a malware-infected PHP server — performed static and dynamic reverse engineering, sandbox analysis (behavioural and network), and applied Zero Trust Architecture (ZTA) principles to contain and remediate the threat.
- Led post-incident forensic investigations including reverse engineering of malicious artefacts, memory and disk forensics (Windows), and network forensics analysis using Belkasoft and standard tooling.

- Conducted security auditing activities aligned with ISO 27001 principles — reviewed firewall configurations, server hardening, patch levels, and access controls against security policy requirements.
- Conducted web application penetration testing and code review to identify common vulnerabilities; produced audit findings with risk ratings and remediation recommendations.

NIELIT, Calicut

June 2024

- Executed exploitation scenarios using Metasploit across multiple target machines; collaborated to trace and analyse real-world attacks occurring in the region.

Technical Skills

VAPT & Red Teaming: Web Application, API, Network, Mobile & Active Directory Penetration Testing, OWASP Top 10, Privilege Escalation, Lateral Movement, Exploit Development

AI & LLM Security: Prompt Injection Research & Testing, AI Agent Penetration Testing, LLM Security Design, OWASP Top 10 LLM, Model Manipulation & Data Exposure Assessment

AppSec & DevSecOps: Snyk, Semgrep, SonarQube, OWASP ZAP, Burp Suite, Acunetix, Checkov, Trivy, Kubesec, Dockle, Gitleaks, GitHub Actions, Azure DevOps

Threat Intelligence & SIEM: Microsoft Sentinel, KQL Advanced Threat Hunting, Detection Rule Engineering, Alert Tuning, MITRE ATT&CK TTP Mapping, Log Source Integration

Cloud Security: Microsoft Defender for Cloud, AWS GuardDuty, CloudTrail, VPC Flow Logs, Azure Diagnostic Settings, Entra ID Monitoring, M365 Defender Connectors

Threat Ops & Defence: Darktrace (Identity / Endpoint / Email / ASM), Threat Investigation & Triage, IOC Analysis, Anomaly Detection, Attack Surface Management

Incident Response & Forensics: Malware Reverse Engineering (Static & Dynamic), Sandbox Analysis, Memory & Disk Forensics (Windows), Network Forensics, Belkasoft, Zero Trust Architecture

Security Auditing: ISO 27001 Principles, Firewall & Server Configuration Review, Access Control Assessment, Risk Rating, Audit Reporting

Programming & Scripting: Python, Bash, PowerShell, KQL, SQL, Java, C

Tools & Platforms: Metasploit, Nessus, Nmap, Wireshark, Kali Linux, Git/GitHub, VS Code, Android Studio

Certifications

eLearnSecurity Junior Penetration Tester (eJPT)	Certified Ethical Hacker (CEH) – In Progress
Certified Penetration Tester (CPT)	Windows Forensics with Belkasoft
Fortinet Certified Associate Cybersecurity	Advanced Digital Forensics with Belkasoft
Google Cybersecurity Professional Certificate	

Projects

Crucible — Agentic LLM Purple-Team Platform | *Python, LLM Red Teaming* **2026**

- Open-source platform that drives multi-hop **indirect prompt-injection** → **tool-misuse** → **exfiltration** chains against tool-using / RAG agents, scores *action-harm* as critical, and reports MITRE ATT&CK-mapped attack-surface coverage completeness.
- Closes the loop by auto-synthesising input/output guardrails, system-prompt hardening patches, and runnable regression tests for every confirmed finding.

Sandworm — AI Malware Reverse-Engineering Platform | *Python* **2026**

- Multi-format RE platform (PE/DLL, ELF, PHP webshells, scripts, Office macros) that reconstructs a sample's lifecycle from static, dynamic, and memory evidence and emits defender-ready **YARA** + **Sigma** detections; runs fully offline with 129 passing tests.

Purple Team Framework — Caldera + Elastic + ATT&CK | *Python* **2026**

- Full offensive-to-defensive loop: Caldera runs adversary simulations (APT29, FIN7, Lazarus, Ransomware; 30+ techniques) → Elastic fires detections → automatically measures which techniques actually detect, flags coverage gaps, and exports a colour-coded ATT&CK Navigator heatmap.

Threat-Intelligence Pipeline — OTX/Abuse.ch → MISP → SIEM | *Python, MISP* **2026**

- End-to-end CTI lifecycle: ingest IOCs from OTX + Abuse.ch feeds, normalise/deduplicate, push net-new IOCs to self-hosted MISP, enrich Microsoft Sentinel/Elastic alerts with VirusTotal & Shodan, and deliver Slack IOC context with MITRE ATT&CK attribution.

Detection-as-Code Pipeline — Microsoft Sentinel | *Python, Sigma, KQL* **2026**

- Manage Sentinel detections as code: engineers write Sigma YAML, CI validates and converts to KQL, CD deploys to Sentinel via REST API, and MITRE ATT&CK coverage is tracked automatically on every merge.

Semgrep Enterprise Rules — SAST Detection Content | *Semgrep* **2026**

- Production-grade Semgrep rules targeting real vulnerability classes (SSRF, JWT-none, unsafe deserialization, SQLi, command injection), each shipping with true/false-positive fixtures, a CI pipeline, and an explanatory blog post.

LLM Security Tester | *Python* **2026**

- Modular, pip-installable CLI that tests LLM applications across 5 attack categories / 25 curated cases (prompt injection, persona override, RAG poisoning) with scored results and CI integration.

SAKSHI — Content-Blind Investigation Assistant | *Python* (Hac'KP 2026, Kerala Police Cyberdome) **2026**

- Agentic assistant that turns scattered digital evidence into ranked, court-ready leads for authorised child-protection units **without ever ingesting or storing the underlying material** — reasoning only over hashes, metadata, and descriptors.

Azure DevSecOps Pipeline | *GitHub Actions, Azure DevOps, Snyk, Semgrep, SonarQube, Gitleaks, Kubesec* **2025**

- Designed production-grade secure CI/CD pipelines integrating SAST, DAST, SCA (Snyk), IaC scanning, and container/Kubernetes security with automated policy gates; enforced shift-left security reducing vulnerability introduction at the pipeline level.

AI Security Research — Prompt Injection & Agent Exploitation **2026**

- Identified 3 critical vulnerabilities in a production AI agent environment (Pokee.ai) via authorised bug bounty research — persona-override prompt injection escalating to live bash infrastructure exfiltration; submitted responsible disclosure report.
- Independently discovered and reported a critical safety bypass in Kimi AI (Moonshot AI); authored a technical report covering attack methodology, root cause analysis, and defensive mitigations.

Earlier Projects | *Applied ML/AI Security Prototypes (2024)*

- **Telegram Sentinel** (DistilBERT + rule-based scam/fraud detection bot) · **Advanced IDS** (LSTM network-anomaly classifier, 99% accuracy) · **APK Malware Identifier** (MLP classifier, 98% accuracy) · **Securify** (CNN/SVM/LR phishing-URL detection, FastAPI).

Achievements

#1 Hall of Fame (Responsible Disclosure)

Discovered two critical vulnerabilities in a live application: Sensitive Data Exposure (exposing the entire user profile database) and a Business Logic Error. Executed responsible disclosure and ranked **1st** on the leaderboard.

AI Vulnerabilities Responsible Disclosure (Sakana AI)

Discovered and responsibly disclosed a prompt injection vulnerability in Sakana AI's platform; acknowledged and rewarded by their team in recognition of the responsible disclosure.

Session Management Vulnerability Disclosure – TinyTax (tinytax.co.uk), UK

Identified and responsibly disclosed a session-related security vulnerability in the TinyTax web application; reported to the vendor with proof-of-concept and remediation guidance.

Critical LDAP Vulnerability Disclosure – Humphreys University, USA

Discovered and reported severe vulnerabilities in LDAP services and user account management systems. Received an official Letter of Appreciation for enhancing the university's security posture.

2nd Place – Cryptic Quest (National Level), SRM Valliammai College

Secured second position in a national-level cybersecurity challenge, demonstrating strong ethical hacking and problem-solving skills.

Education

Vel Tech Rangarajan Dr. Sagunthala R&D Institute of Science and Technology

2022 – 2026

B.Tech in Computer Science and Engineering (Cybersecurity)

Avadi, Tamil Nadu